



Reporte Final VulnerableApp

Nombre: Guillermo Larzen Vazquez Rangel

Grupo: IDGS17

Matricula: 2024171016

Maestro: Gerardo Ramírez Villarreal

Materia: Seguridad en el Desarrollo de Aplicaciones

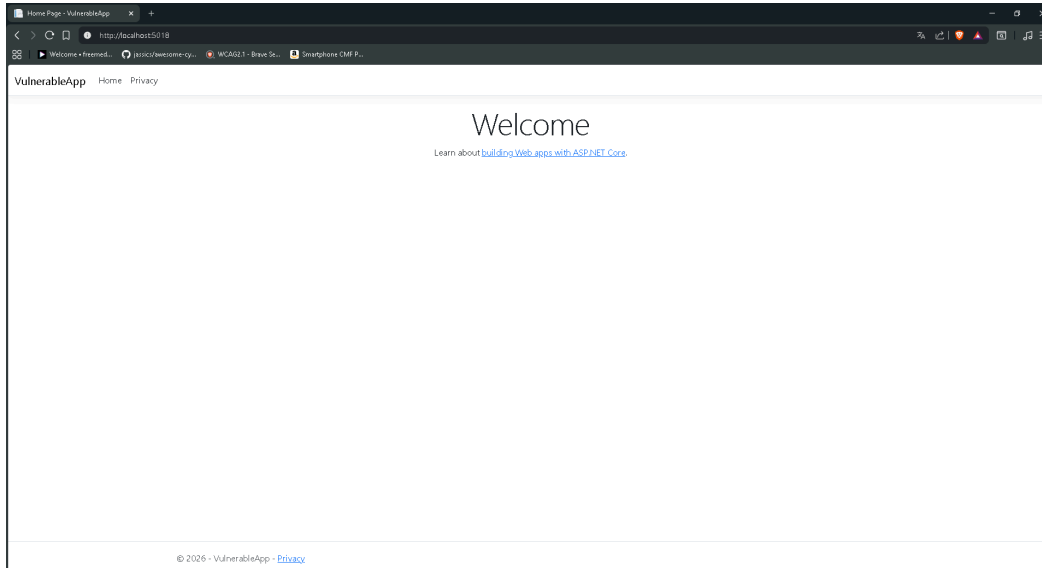
P2A

git clone <https://github.com/GLVR2004/VulnerableApp>

dotnet restore

dotnet ef database update

dotnet run



```
Selecionar MINGW64/c/Users/Huesos/Documents/VulnerableApp

Huesos@DESKTOP-HLGDDSV MINGW64 ~/Documents/VulnerableApp (main)
$ dotnet build
Restauración completada (0.4s)
  VulnerableApp net10.0 realizado correctamente (0.5s) → bin\Debug\net10.0\VulnerableApp.dll

Compilación realizado correctamente en 1.4s

Huesos@DESKTOP-HLGDDSV MINGW64 ~/Documents/VulnerableApp (main)
$ dotnet run
Usando la configuración de inicio de C:\Users\Huesos\Documents\VulnerableApp\Properties\launchSettings.json...
Compilando...
info: Microsoft.Hosting.Lifetime[14]
      Now listening on: http://localhost:5018
info: Microsoft.Hosting.Lifetime[0]
      Application started. Press Ctrl+C to shut down.
info: Microsoft.Hosting.Lifetime[0]
      Hosting environment: Development
info: Microsoft.Hosting.Lifetime[0]
      Content root path: C:\Users\Huesos\Documents\VulnerableApp
warn: Microsoft.AspNetCore.HttpsPolicy.HttpsRedirectionMiddleware[3]
      Failed to determine the https port for redirect.
```

```
Data> AppDbContext.cs > ...
1  using Microsoft.EntityFrameworkCore;
2  using VulnerableApp.Models;
3  namespace VulnerableApp.Data
4  {
5      13 references | You, 22 minutes ago | 1 author (You)
6      public class AppDbContext : DbContext
7      {
8          1 reference
9          public AppDbContext(DbContextOptions<AppDbContext> options) : base(options) { }
10         2 references
11         public DbSet<User> Users { get; set; }
12         0 references
13         protected override void OnModelCreating(ModelBuilder modelBuilder)
14         {
15             // Definir precisión para el tipo decimal
16             modelBuilder.Entity<User>().Property(u => u.Balance).HasPrecision(10, 2);
17             modelBuilder.Entity<User>().HasData(
18                 new User { Id = 1, Username = "admin", Password = "admin", Email = "admin@test.com", Balance = 1000m, CreatedAt = new DateTime(2026, 1, 1) },
19                 new User { Id = 2, Username = "user1", Password = "123456", Email = "user1@test.com", Balance = 500m, CreatedAt = new DateTime(2026, 1, 1) },
20                 new User { Id = 3, Username = "user2", Password = "password", Email = "user2@test.com", Balance = 750m, CreatedAt = new DateTime(2026, 1, 1) }
21             );
22         }
23     }
24 }
```

P2B

La aplicación utiliza concatenación de cadenas para construir consultas SQL en `FromSqlRaw`. Al ingresar caracteres especiales ('), el atacante puede cerrar la cadena original y añadir condiciones propias (ej. `OR 1=1`), forzando al sistema a devolver información no autorizada o provocando errores de sintaxis que exponen la estructura de la base de datos.

```

1  You, 17 hours ago | 1 author (You)
2  using Microsoft.AspNetCore.Mvc;
3  using Microsoft.EntityFrameworkCore;
4  using VulnerableApp.Data;
5  using VulnerableApp.Models;
6
7  You, 17 hours ago | 1 author (You)
8  namespace VulnerableApp.Controllers
9  {
10     1 reference | You, 17 hours ago | 1 author (You)
11     public class SearchController : Controller
12     {
13         2 references
14         private readonly ApplicationDbContext _db;
15
16         0 references
17         public SearchController(ApplicationDbContext db)
18         {
19             _db = db;
20         }
21
22         0 references
23         public IActionResult Index(string search)
24         {
25             if (string.IsNullOrEmpty(search))
26             {
27                 return View(new List<User>());
28             }
29
30             string query = "SELECT * FROM Users WHERE Username LIKE '%" + search + "%'";
31
32             var users = _db.Users.FromSqlRaw(query).ToList();
33
34             return View(users);
35         }
36     }
37 }

```

An unhandled exception occurred while processing the request.

SQLException: Incorrect syntax near '1'.
Unclosed quotation mark after the character string

```
Microsoft.Data.SqlClient.SqlConnection.OnError(SqlException exception, bool breakConnection, Action<Action> wrapCloseInAction)
```

Stack Query Cookies Headers Routing

SQLException: Incorrect syntax near '1'. Unclosed quotation mark after the character string ''.

P2C

VulnerableAppHomePrivacy

Login

Usuario:admin

Password:

Entrar

VulnerableAppHomePrivacy

Bienvenido al Dashboard, admin

Cerrar sesión

VulnerableAppHomePrivacy

Bienvenido al Dashboard, user1

Cerrar sesión

VulnerableAppHomePrivacy

Login

Usuario:

Password:

Entrar

Credenciales incorrectas